

Module 6: Cybersecurity Fundamentals

Day 3 - Phishing & Email Security



Module 6 — Course Overview

Day	Date	Topic
✓ Day 1	Mar 18	Threat Intelligence & Frameworks
✓ Day 2	Mar 25	URL Analysis & Vulnerability Fundamentals
▶ Day 3	Apr 15	Phishing & Email Security
Day 4	Apr 22	Password Security & Network Traffic Analysis
Day 5	Apr 29	Malware Analysis & SIEM
Day 6	May 6	Incident Response Reporting
Day 7	May 13	Capstone — Simulated Incident Investigation

What We Learned So Far — Days 1–2

- Day 1 — Threat Intelligence: Kill Chain, ATT&CK, OSINT, TI lifecycle, STIX/TAXII
- Day 2 — URL Analysis & Vulnerabilities:
 - URL anatomy, obfuscation, URLScan, VirusTotal, defanging IOCs
 - Vulnerability scanning: Nmap, Nessus
 - CVEs, CVSS scoring, NVD, Exploit-DB, SearchSploit
 - Exploitation: SQLi, XSS, buffer overflow, Metasploit
 - OWASP Top 10, Burp Suite

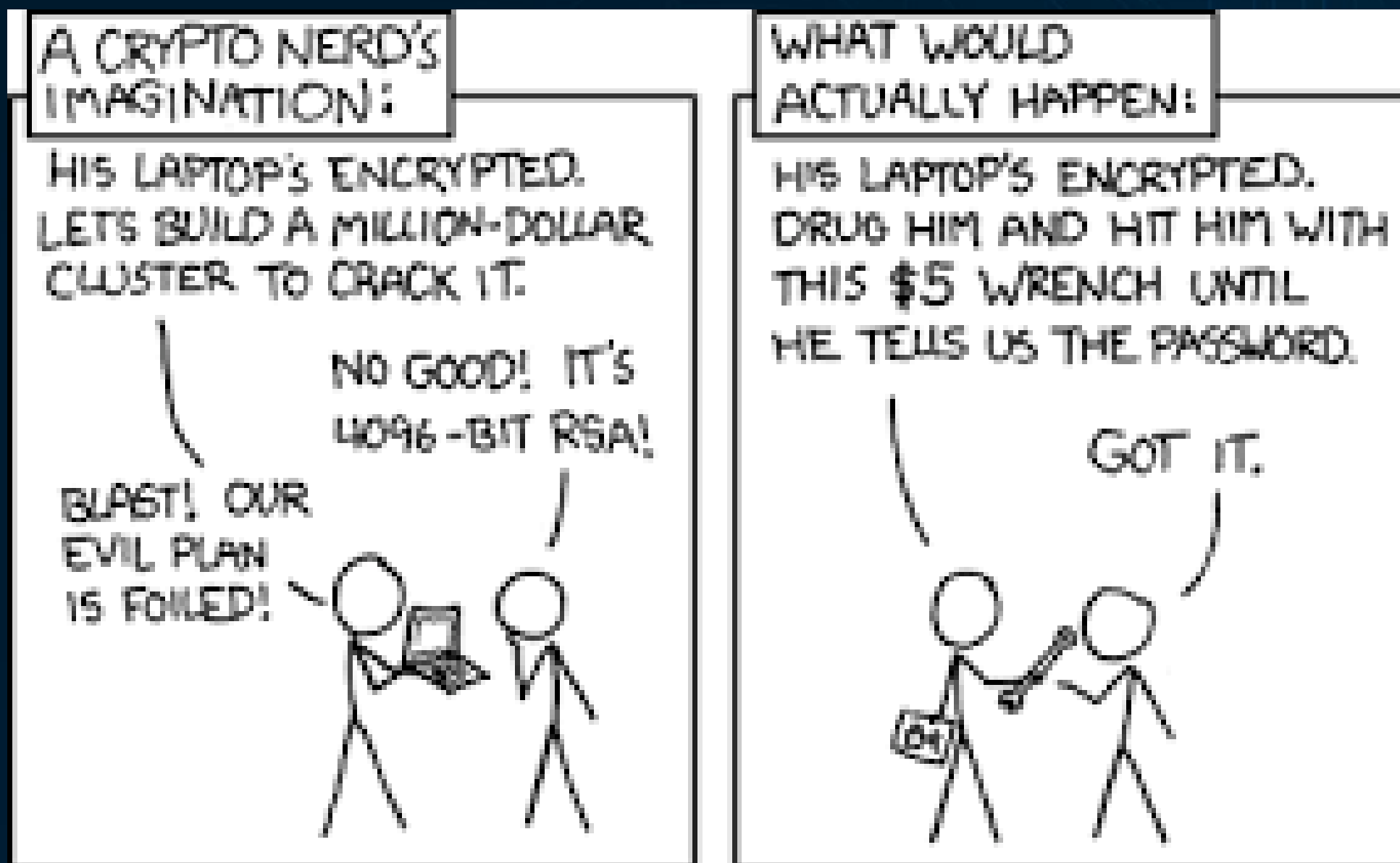
The Human Element

- **Why attack humans?**
 - Technical controls are improving
 - Humans are predictable
 - Emotions override logic
 - One click bypasses all defenses
- **"Amateurs hack systems. Professionals hack people."**

What is Social Engineering?

- **Social Engineering:** Psychological manipulation to trick people into security mistakes
- **Core principles exploited:**
 - **Authority:** Obey those in charge
 - **Urgency:** Act now, think later
 - **Fear:** Avoid negative consequences
 - **Trust:** Help those who seem legitimate
 - **Curiosity:** What's in this attachment?

What is Social Engineering?



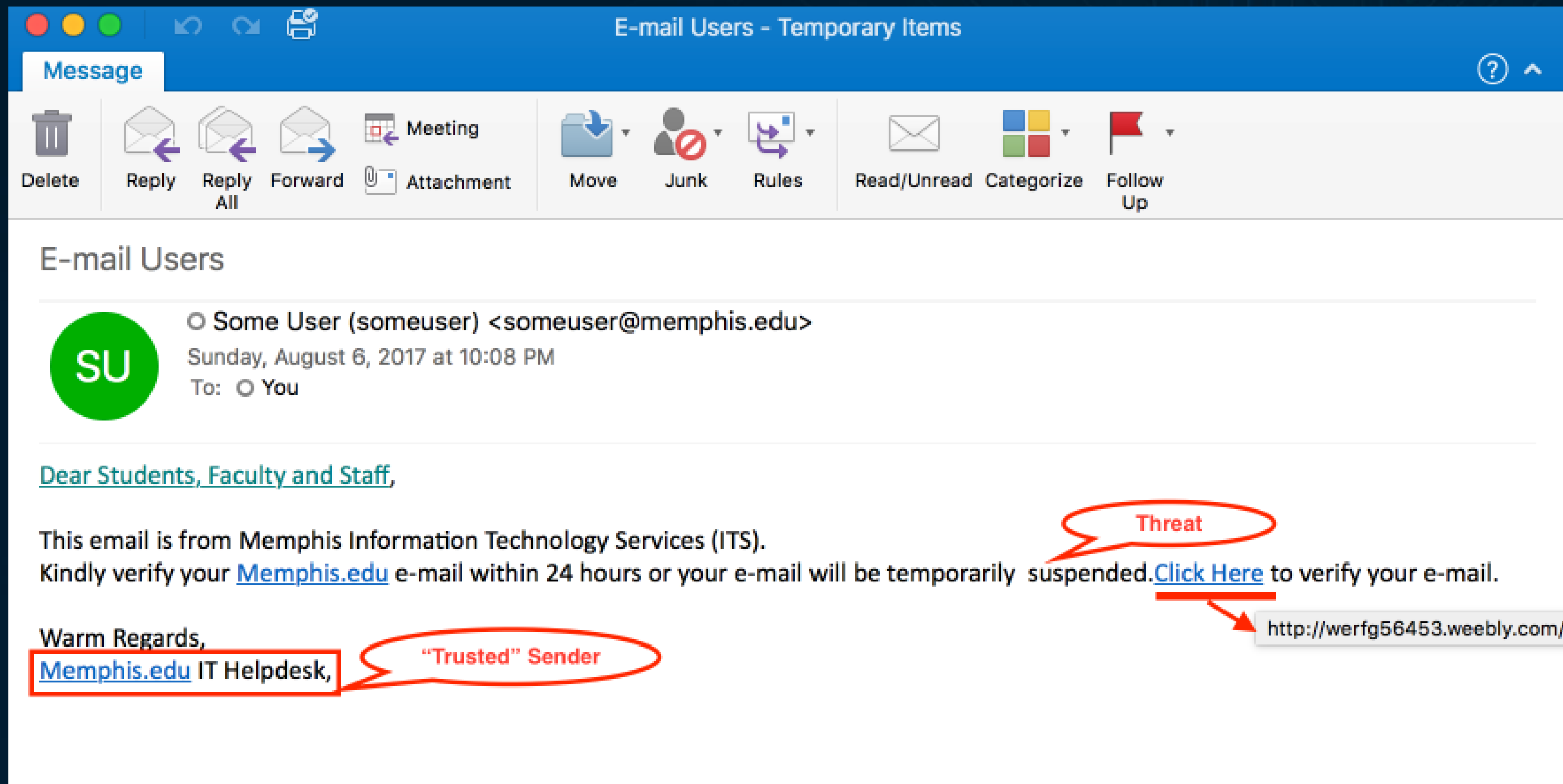
Social Engineering Attack Types

- **Common techniques:**
 - **Phishing:** Fraudulent emails seeking information/action
 - **Vishing:** Voice phishing (phone calls)
 - **Smishing:** SMS phishing
 - **Pretexting:** Creating false scenarios
 - **Baiting:** Leaving infected devices
 - **Tailgating:** Following through secure doors

Phishing Overview

- **Phishing:** Fraudulent messages impersonating legitimate entities
- **Goals:**
 - Steal credentials
 - Install malware
 - Trick into wire transfers
 - Harvest information
 - Scale:** 3.4 billion phishing emails sent daily

Phishing Overview



The screenshot shows an email client window titled "E-mail Users - Temporary Items". The email is from "Some User (someuser) <someuser@memphis.edu>" dated "Sunday, August 6, 2017 at 10:08 PM". The email body contains the following text:

[Dear Students, Faculty and Staff,](#)

This email is from Memphis Information Technology Services (ITS).
 Kindly verify your [Memphis.edu](#) e-mail within 24 hours or your e-mail will be temporarily suspended. [Click Here](#) to verify your e-mail.

Warm Regards,
[Memphis.edu](#) IT Helpdesk,

Annotations on the screenshot:

- A red speech bubble labeled "Threat" points to the phrase "suspended. Click Here to verify your e-mail."
- A red speech bubble labeled "'Trusted' Sender" points to the "Memphis.edu IT Helpdesk," text.
- A red arrow points from the underlined "Click Here" link to a tooltip showing the URL: <http://werfg56453.weebly.com/>

Phishing Email Anatomy

- **Email components to analyze:**
 - **From address:** Display name vs actual address
 - **Reply-To:** Where replies actually go
 - **Subject:** Urgency or curiosity triggers
 - **Body:** Grammar, tone, requests
 - **Links:** Hover to check destination
 - **Attachments:** Potentially malicious files
 - **Headers:** Full routing information

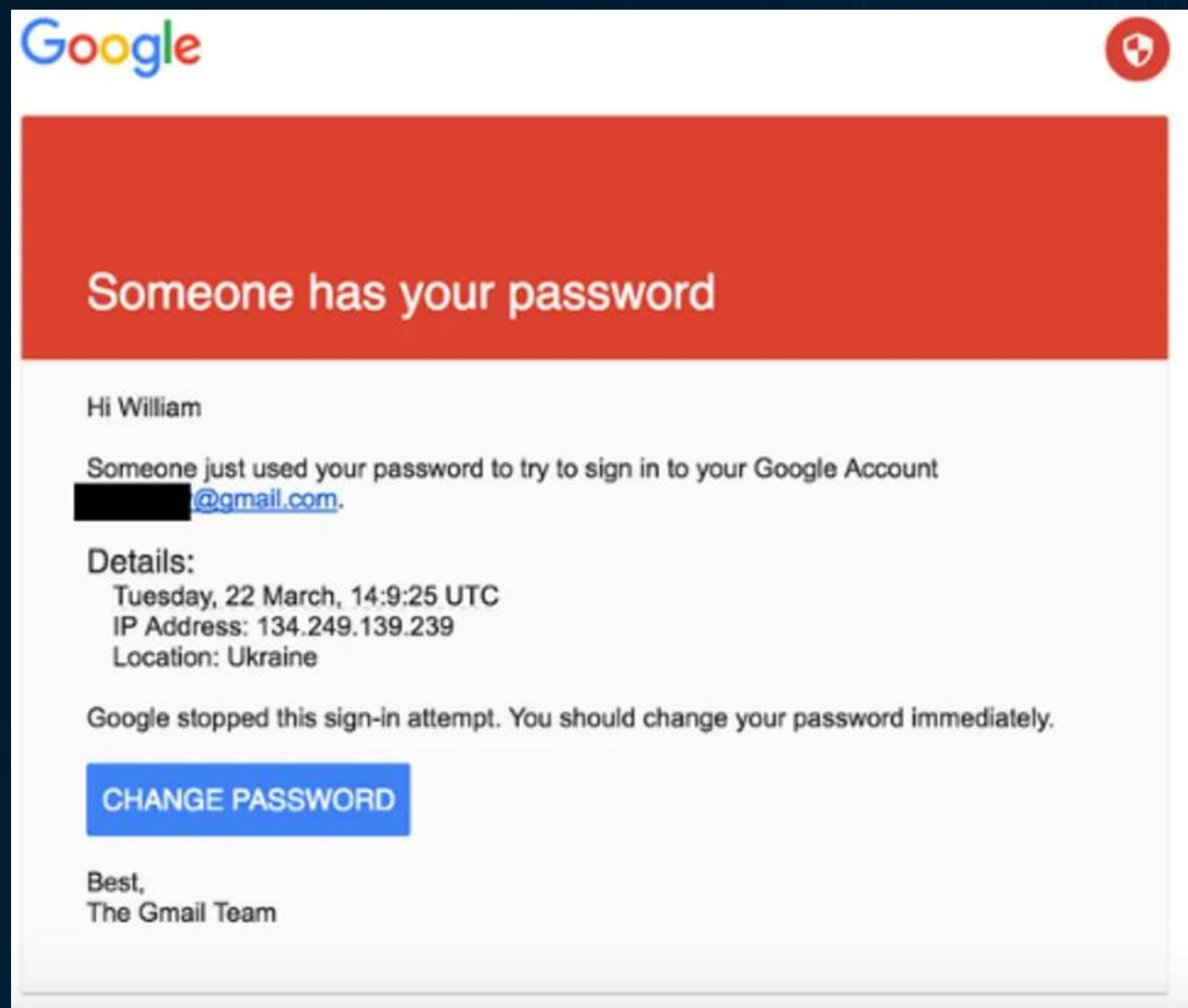
Phishing Red Flags

- **Warning signs:**
 - ⚠ Generic greeting ("Dear Customer")
 - ⚠ Urgency or threats
 - ⚠ Suspicious sender address
 - ⚠ Mismatched or suspicious links
 - ⚠ Grammar and spelling errors
 - ⚠ Unexpected attachments
 - ⚠ Requests for sensitive information
 - ⚠ Too good to be true offers

Spear Phishing

- **Spear Phishing:** Targeted attacks using personal information
- **Characteristics:**
 - Researched target (OSINT)
 - Personalized content
 - Higher success rate
 - Harder to detect
 - Often targets executives or finance

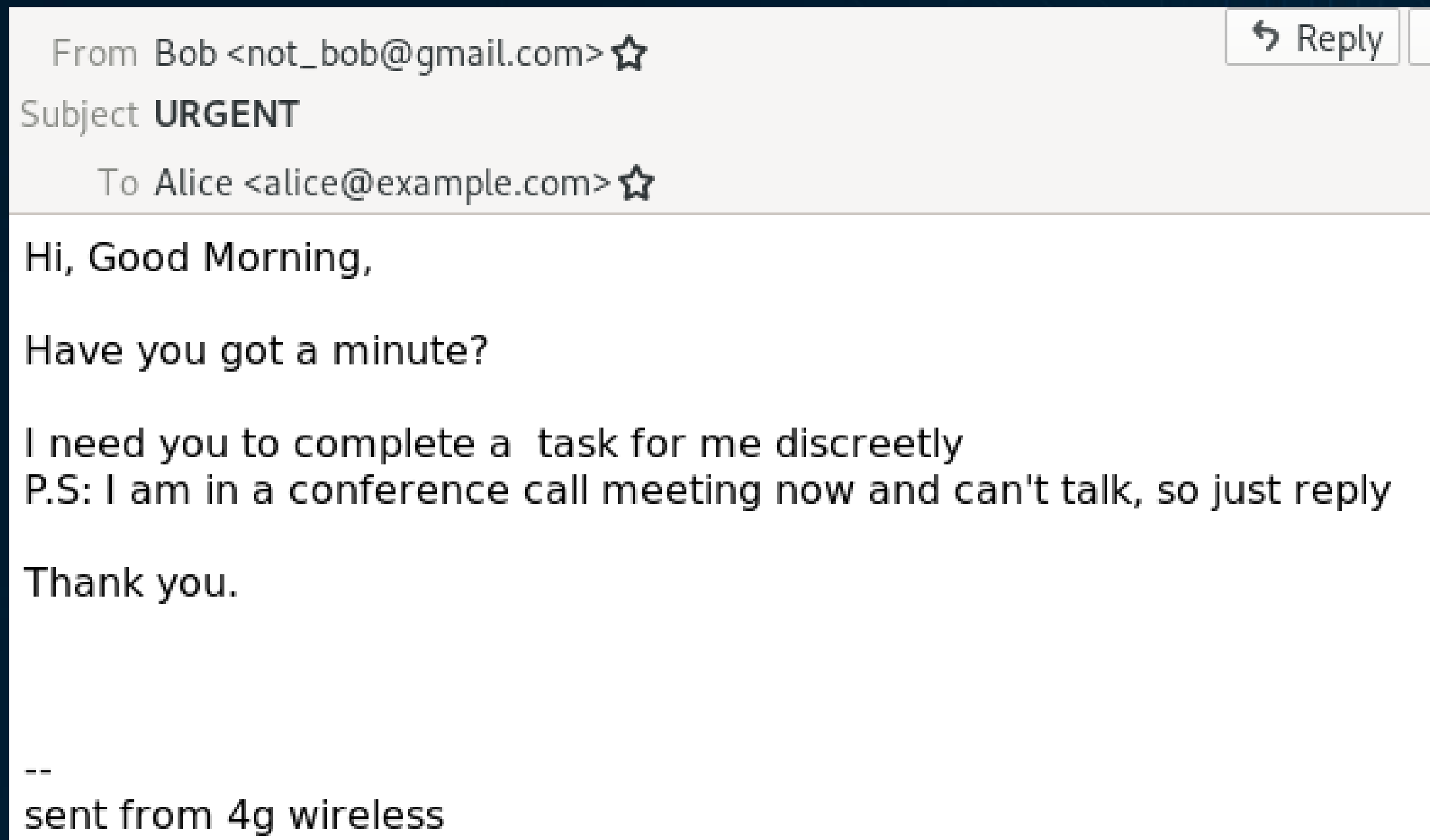
Spear Phishing



Business Email Compromise (BEC)

- **BEC:** Impersonating executives or business partners
- **Common scenarios:**
 - "CEO" requests urgent wire transfer
 - "Vendor" sends updated payment details
 - "Lawyer" requires confidential deal info
 - **Impact:** \$2.7 billion lost in 2022 (FBI IC3)

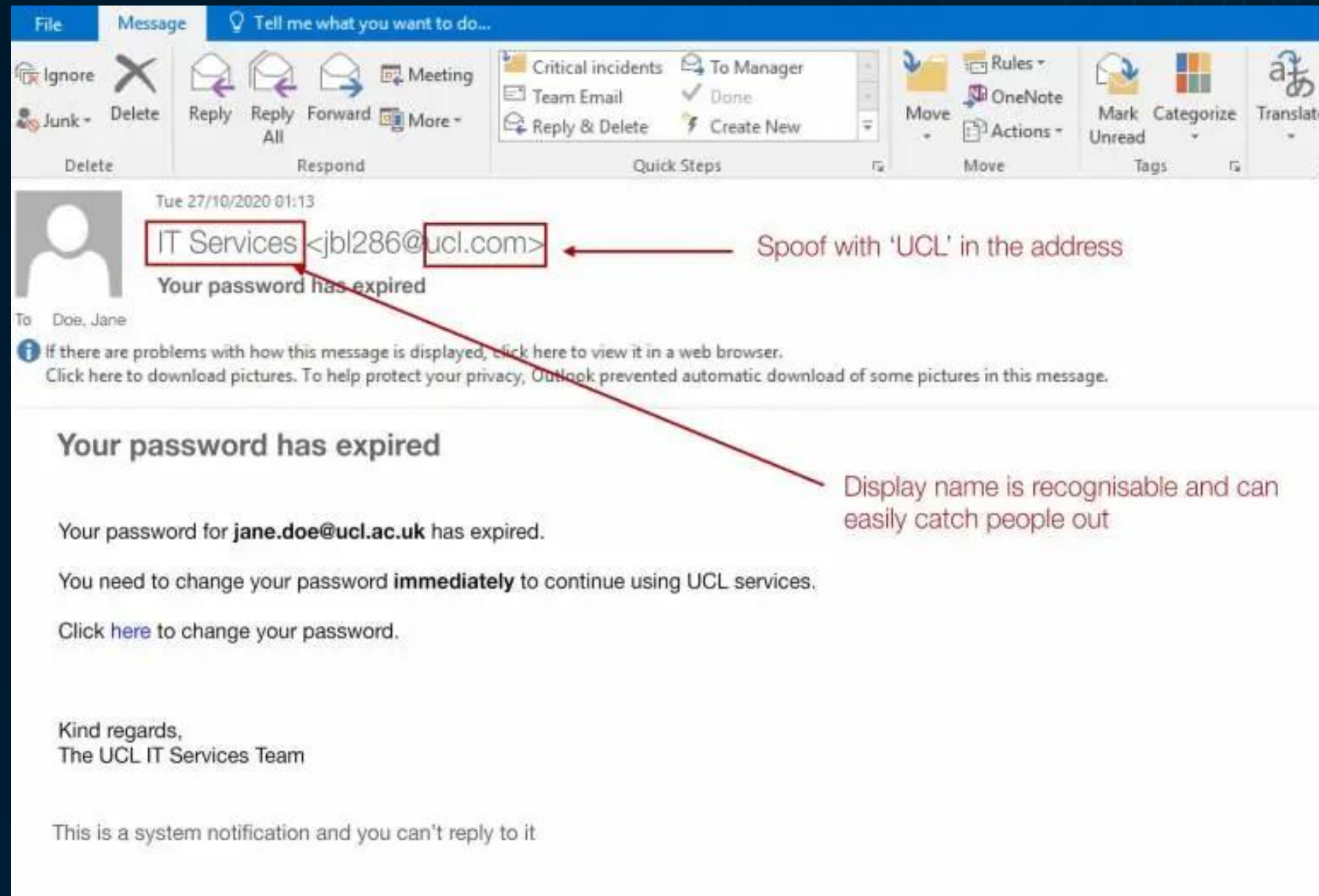
Business Email Compromise (BEC)



Whaling

- **Whaling:** Phishing targeting executives (the "big fish")
- **Why target executives:**
 - Broader access
 - Authority to approve transfers
 - Valuable information access
 - Less time for careful review
 - May bypass security awareness training

Whaling



Clone Phishing

- **Clone Phishing:** Copying legitimate emails with malicious modifications
- **Process:**
 1. Obtain legitimate email (or create realistic version)
 2. Replace links/attachments with malicious versions
 3. Resend as "updated" or "corrected" version
- **Very difficult to detect**

Phishing Kits and Services

- **Cybercrime commercialization:**
 - Pre-built phishing kits (\$50-\$500)
 - Phishing-as-a-Service
 - Credential harvesting platforms
 - Bulletproof hosting
 - Money mule networks
- **Lowers barrier to entry significantly**

Quishing — QR Code Phishing

- QR codes bypass email link-scanning security controls
- How it works:
 - Malicious URL embedded in QR code image (image scanners miss it)
 - User scans with phone → opens link in mobile browser
 - Mobile browsers often lack corporate proxy/security controls
- Common lures: fake MFA prompts, parking meters, package delivery
- Red flags: unexpected QR codes in email, urgency messaging
- Defense: QR-aware email security, user training, mobile MDM
- MITRE: T1566.002 — Spearphishing Link



CYBERLABS

Vishing — Voice Phishing Deep Dive

- Vishing = Voice phishing over telephone
- Common pretexts:
 - IT helpdesk: "Your account is compromised, I need to verify you"
 - Bank fraud team: "Suspicious activity — please confirm details"
 - HR/payroll: "Update your direct deposit for the new pay cycle"
 - Government: IRS, Social Security, law enforcement impersonation
- Advanced techniques: caller ID spoofing, AI voice cloning (deepfake audio)
- MGM (2023): one vishing call to IT helpdesk → \$100M+ compromise
- Defense: call-back verification, never act on inbound calls alone

Analyzing Phishing Emails

- **Investigation steps:**
 - 1.Examine headers (Received, Return-Path, X-headers)
 - 2.Analyze sender domain (WHOIS, reputation)
 - 3.Inspect links without clicking
 - 4.Submit to VirusTotal
 - 5.Check attachments in sandbox
 - 6.Document IOCs (IPs, domains, hashes)

Email Header Analysis

- **Critical headers:**

```
Return-Path: <actual-bounce@address.com>  
Received: from server.example.com (IP)  
From: "Display Name" <sender@domain.com>  
Reply-To: hidden-reply@attacker.com  
X-Originating-IP: [sender IP]  
Authentication-Results: spf=fail dkim=fail
```

- **Headers reveal the truth**

Phishing Simulation Programs

- **Security awareness testing:**
 - Send simulated phishing emails
 - Track who clicks, who reports
 - Provide immediate training
 - Measure improvement over time
 - Tools: GoPhish, KnowBe4, Proofpoint
- **Ethical considerations important**

Why Email Authentication Matters

- **Problem:** Email was designed without authentication
- Anyone can claim any From address
- No built-in verification
- Perfect for impersonation
- **Solution:** Email authentication protocols
 - SPF, DKIM, DMARC

SPF - Sender Policy Framework

- **SPF:** Specifies authorized sending servers
- **How it works:**
 1. Sending server delivers email
 2. Receiving server checks sender's SPF record
 3. SPF record lists authorized IPs/domains
 4. Email passes or fails SPF check
- **DNS TXT record:**

```
v=spf1 include:_spf.google.com -all
```


SPF Record Syntax

- **SPF components:**

```
v=spf1          # Version
ip4:192.168.1.0/24 # Allow IP range
include:_spf.google.com # Include other SPF
a              # Allow A record IPs
mx            # Allow MX record servers
-all         # Fail all others
~all        # Softfail all others
```

DKIM - DomainKeys Identified Mail

- **DKIM:** Cryptographic email signing
- **How it works:**
 1. Sending server signs email with private key
 2. Signature added to email header
 3. Public key published in DNS
 4. Receiving server verifies signature
- **Proves email wasn't modified in transit**

DKIM Headers

- **DKIM-Signature header:**

```
DKIM-Signature: v=1; a=rsa-sha256;  
d=example.com; s=selector;  
h=from:to:subject:date;  
bh=base64hash;  
b=signaturebase64;
```

- **Key components:**
 - d**= Domain claiming responsibility
 - s**= Selector (which key to use)
 - h**= Headers that were signed
 - b**= The signature itself

DMARC - Domain-based Message Authentication

- **DMARC:** Policy and reporting layer on top of SPF/DKIM
- **Provides:**
 - Policy instructions (none/quarantine/reject)
 - Alignment checking
 - Reporting mechanism
- **DNS record:**

```
v=DMARC1; p=reject; rua=mailto:dmarc@example.com
```


DMARC Alignment

- **Alignment:** Authenticated domain matches visible From
- **SPF Alignment:**
 - Envelope sender domain = Header From domain
- **DKIM Alignment:**
 - DKIM signing domain (d=) = Header From domain
- **Why it matters:** Without alignment, attackers can pass SPF/DKIM but still spoof From

DMARC Policies

- **DMARC policy options:**
 - p=none**: Monitor only (no action)
 - p=quarantine**: Send to spam folder
 - p=reject**: Block delivery entirely
- **Implementation approach:**
 1. Start with p=none (monitor)
 2. Analyze reports, fix legitimate sources
 3. Move to p=quarantine
 4. Finally, p=reject

Reading Authentication Results

- **Authentication-Results header:**

```
Authentication-Results: mx.google.com;  
spf=pass (sender IP is 209.85.220.41)  
smtp.mailfrom=example.com;  
dkim=pass header.d=example.com;  
dmarc=pass (p=REJECT)  
header.from=example.com
```

- **Tells you:** What passed, what failed, why

Email Security Analysis Workflow

- **Analyzing suspicious email:**
 1. Check Authentication-Results (SPF/DKIM/DMARC)
 2. Examine full headers for routing
 3. Analyze sender domain reputation
 4. Inspect links with URL analysis tools
 5. Submit attachments to sandbox
 6. Document findings and IOCs

MGM Resorts 2023 — Real-World Phishing Attack

- Attack vector: Vishing + LinkedIn OSINT → social engineering IT helpdesk
- Attacker impersonated employee, called IT, got credentials reset
- Gained OKTA admin access → spread to MGM's systems
- Impact: \$100M+ loss, 10 days of disruption
- Lesson: No SPF/DKIM check stops a human-based credential reset
- MITRE: T1598 (Phishing for Info), T1566.004, TA0001 Initial Access

Day 3 Summary — Phishing & Email Security

- Social engineering exploits authority, urgency, and fear
- Attack types: phishing, spear phishing, BEC, whaling, clone phishing, quishing, vishing
- Analyzing emails: headers reveal true path, check authentication results
- SPF - validates sending server | DKIM — cryptographic signature | DMARC — policy enforcement
- Quishing: QR codes bypass email link-scanners; scan on mobile = no corp controls
- Vishing: voice calls can reset credentials — MGM 2023 lost \$100M+ via one call
- Real example: MGM 2023 — vishing + LinkedIn OSINT → full network compromise

© CyberLabs Technologies

Thank You

